

## Actividad 01 · Análisis y planificación del pentest

**Caso: Aurora Market** — Hacker Women Council · Ethical Hacking

Nombre completo: luisa Fernanda naranjo Fernández Fecha: 27/8/2026

### 1. Propósito del pentest

Propósito 1. Descubrir y confirmar vulnerabilidades en el control de acceso (control de acceso roto / IDOR) de la plataforma online de Aurora Market, centrándose en el incidente que fue informado por un usuario que accedió a datos que parecían ser de otra cuenta.

Propósito 2. Analizar la solidez de los sistemas de autenticación, manejo de sesiones y separación de funciones (cliente frente a personal administrativo), averiguando si se puede llevar a cabo un aumento horizontal o vertical en los privilegios.

Propósito 3. Evaluar el grado de exposición de datos sensibles de los clientes (incluyendo nombres, correos electrónicos, números de teléfono, direcciones de envío e historial de compras) y elaborar un informe con riesgos priorizados y sugerencias prácticas para el equipo de desarrollo.

Consejo aplicable: los tres propósitos abordan la inquietud planteada por la dirección — "¿Qué tan segura es realmente nuestra aplicación? " — y ofrecen un aporte directo al negocio: salvaguardar la confianza de los usuarios.

### 2. Alcance

Se revisará

- La plataforma web de Aurora Market en el dominio/URL que ha sido claramente autorizado.
- Registro de usuario, inicio de sesión, recuperación de contraseña y administración de sesiones.
- Perfil del usuario, carrito de compras, proceso de compra y seguimiento del estado de los pedidos.
- Sección administrativa de la plataforma (gestión de productos, usuarios y pedidos), a la que se puede acceder desde la aplicación autorizada.
- Interfaces y puntos finales utilizados por la aplicación web.
- Autorizaciones de acceso entre cuentas del mismo rol y entre roles diferentes.
- Base de datos, sólo en la medida que sea accesible a través de la aplicación (p. ej. inyección SQL), sin requerir la extracción masiva de datos reales.

Fuera del alcance

- Redes sociales asociadas con la empresa.
- Dispositivos personales de los empleados y sus correos electrónicos.

- Proveedores externos y servicios de terceros (como pasarelas de pago, alojamiento, mensajería) que no estén incluidos en el acuerdo firmado.
- Cualquier sistema interno que no esté mencionado específicamente.
- Ataques de denegación de servicio (DoS/DDoS) y pruebas de carga destructivas.
- Técnicas de ingeniería social y phishing dirigidas al personal.
- Modificación, eliminación o extracción de datos reales de los clientes.
- Evaluaciones de seguridad física en las instalaciones.

### 3. Autorización y condiciones

#### Permisos necesarios

- Aprobación oficial por escrito, firmada por un representante que tenga facultades legales en Aurora Market (contrato más carta de consentimiento).
- Documento que detalle los dominios, URLs e IPs permitidas, junto con la franja horaria aprobada.
- Acuerdo de confidencialidad (NDA) firmado por cada miembro del equipo.
- Cuentas de prueba con diferentes roles (al menos dos de cliente y una administrativa) configuradas para la actividad.
- Permiso del proveedor de alojamiento/nube, si sus términos de servicio lo requieren.
- Un contacto técnico de emergencia disponible durante todo el período de pruebas.

#### Condiciones establecidas

- La evaluación se lleva a cabo únicamente en la aplicación web autorizada.
- No se llevarán a cabo acciones que interrumpan de forma intencionada el funcionamiento de la plataforma.
- No se modificará ni se afectará la información real de los clientes; si se accede a datos reales, se documentará la evidencia mínima y redactada, y se informará de inmediato.
- Las evaluaciones se llevan a cabo en momentos de baja actividad (franja horaria acordada, por ejemplo, de 00:00 a 05:00 h).
- Se favorece el uso de datos y cuentas simuladas siempre que haya un entorno de pruebas disponible.
- Se debe notificar de inmediato cualquier hallazgo grave o indicio de un compromiso previo (existe un procedimiento de escalamiento establecido).
- Toda la evidencia se guarda de forma cifrada y se entrega o elimina al finalizar el proyecto.

- Se garantiza una confidencialidad absoluta: el informe se proporciona únicamente a los contactos autorizados.
- El equipo anota la dirección IP de origen, los horarios y las acciones realizadas para que Aurora Market pueda diferenciar entre pruebas y un ataque real.

#### 4. Tipo de pentesting

Tipo seleccionado: GRAY-BOX

##### Justificación

El escenario describe de manera precisa un caso de caja gris: Aurora Market no proporciona todos los detalles técnicos de su infraestructura, pero el equipo está al tanto de la existencia de una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios, además de contar con cuentas de acceso.

También es la opción más idónea porque:

- El incidente a investigar (un usuario accediendo a datos de otra cuenta) solo puede comprobarse desde dentro, utilizando cuentas legítimas de varios usuarios. En un enfoque de caja negra puro, sería prácticamente imposible abordarlo adecuadamente.
- Replica de manera realista al atacante más probable: alguien que simplemente se inscribe como cliente.
- Optimiza el tiempo y minimiza el ruido y el riesgo de pruebas destructivas, cumpliendo con la condición de no intervenir en la operación.

Para contrastar:

- Black-box: el evaluador no posee información previa sobre la infraestructura, código o configuraciones.
- White-box: el evaluador tiene acceso completo (código fuente, arquitectura, configuraciones).

#### 5. Planificación

| Elemento                      | Definición para Aurora Market                                                                                                                                |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Objetivos</b>              | Los tres del punto 1: validar el fallo de control de acceso, evaluar autenticación/roles y medir la exposición de datos de clientes.                         |
| <b>Alcance</b>                | Aplicación web autorizada, su área administrativa y sus APIs. Excluye redes sociales, equipos y correos de empleados, proveedores externos y otros sistemas. |
| <b>Permisos y condiciones</b> | Carta de autorización firmada, NDA, cuentas de prueba, ventana nocturna, prohibición de DoS y de afectar datos reales, canal de escalamiento.                |

| Elemento                           | Definición para Aurora Market                                                                                                                                                                                                                                                                                                      |
|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Metodología a utilizar             | <b>OWASP WSTG</b> (Web Security Testing Guide) como guía de pruebas, apoyada en <b>OWASP Top 10</b> para clasificar, <b>PTES</b> para estructurar el proceso y <b>CVSS 3.1</b> para priorizar.                                                                                                                                     |
| Recopilación de información previa | Entrevista con el equipo de tecnología; detalle del incidente reportado (fecha, cuenta, logs disponibles); inventario de funcionalidades y roles; stack tecnológico; alta de cuentas de prueba; OSINT pasivo (subdominios, DNS, certificados, repositorios públicos, filtraciones de credenciales).                                |
| Recursos necesarios                | Equipo de 3–4 personas (líder de proyecto, 2 pentesters, responsable del informe). Herramientas: Burp Suite / OWASP ZAP, Nmap, Nikto, Nuclei, ffuf o dirsearch, sqlmap (uso controlado), navegador con proxy. Infraestructura: equipos cifrados, IP fija autorizada o VPN, repositorio seguro de evidencias, plantilla de informe. |
| Programación del pentest           | <b>Semana 1:</b> planificación, firma de autorizaciones y reconocimiento. <b>Semana 2:</b> análisis de vulnerabilidades y explotación controlada (ventana 00:00–05:00 h). <b>Semana 3:</b> post-explotación limitada, redacción del informe, presentación de resultados y retest de correcciones.                                  |

## 6. Etapas del pentest en Aurora Market

1. Reconocimiento. Realización de OSINT pasivo sobre el dominio, que incluye subdominios, registros DNS, certificados, tecnologías en uso, correos corporativos expuestos y posibles filtraciones. Posteriormente, se lleva a cabo un mapeo activo permitido de la aplicación, abarcando rutas, endpoints, parámetros, formularios, tipos de usuario y el proceso de compra completo. Objetivo: identificar la superficie de ataque que el cliente no ha documentado.
2. Evaluación de vulnerabilidades. Se realiza un escaneo automatizado seguido de una verificación manual, priorizando: errores en el control de acceso e IDOR (a raíz del incidente mencionado), fallos de autenticación y en la gestión de sesiones, inyecciones, exposición de datos sensibles, configuraciones erróneas y controles de acceso a la parte administrativa. Se eliminan los falsos positivos y cada hallazgo se clasifica utilizando el sistema CVSS.
3. Explotación. Comprobación controlada de los hallazgos encontrados. Específicamente: usando dos cuentas de prueba, comprobar si al modificar identificadores de pedido o usuario, se puede acceder a la información de la otra cuenta, así como testar el escalamiento horizontal y vertical hacia el panel administrativo. Serán únicamente pruebas conceptuales, sin alterar datos reales ni afectar la disponibilidad del servicio.
4. Post-explotación. Evaluar el impacto real: qué tipo y cantidad de información estaría disponible, si se logra acceder al área administrativa y si es posible mantener persistencia o hacer pivotaje. Todo esto de manera simulada y documentada, sin extraer información real de clientes,

eliminando posteriormente cualquier cuenta, archivo o artefacto creado durante el proceso de pruebas.

5. Informe. Resumen ejecutivo que responde de manera directa a la pregunta de la dirección, junto con el detalle técnico de cada hallazgo acompañado de evidencia que se puede reproducir, nivel de riesgo, impacto en el negocio y recomendaciones de remediación específicas para el equipo de desarrollo. Se presenta un plan de corrección priorizado y una fecha para la re-evaluación.

## 7. Investigación

Metodología seleccionada: OWASP WSTG — Guía de Pruebas de Seguridad Web (complementada por PTES para el ciclo completo del proyecto).

¿Por qué es beneficiosa para este proyecto? Es una metodología accesible y gratuita, reconocida en el sector, y diseñada específicamente para aplicaciones web, que es justo el ámbito autorizado de Aurora Market. Estructura las pruebas en categorías definidas —gestión de identidad, autenticación, autorización, gestión de sesiones, validación de entradas, lógica de negocio, criptografía— lo que facilita demostrar una cobertura completa y trazable ante el cliente.

La sección dedicada a las pruebas de autorización aborda directamente el problema reportado (un usuario accediendo a datos de otra cuenta), lo que dirige el trabajo hacia la inquietud específica que dio origen al encargo. Al tratarse de una guía de pruebas en lugar de un ataque destructivo, se ajusta perfectamente a las condiciones establecidas: no interrumpir el servicio ni comprometer datos reales. Por último, al alinear los hallazgos con OWASP Top 10 y CVSS, el informe se encuentra en un lenguaje que el equipo de desarrollo de Aurora Market puede comprender y poner en práctica sin necesidad de traducción adicional.